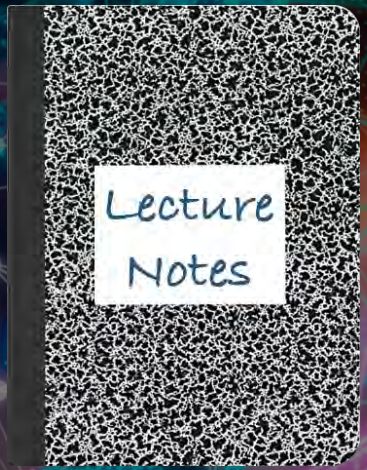


CS 419: Computer Security

Week 1: Part 4

Adversaries & Incentives

Paul Krzyzanowski

© 2022-2026 Paul Krzyzanowski. No part of this content may be reproduced or reposted in whole or in part in any manner without the permission of the copyright owner.

Protection: Know Your Enemy!

Different attackers

… have different goals

… and different skill levels



"If you know the enemy and know yourself, you need not fear the result of a hundred battles. If you know yourself but not the enemy, for every victory gained you will also suffer a defeat. If you know neither the enemy nor yourself, you will succumb in every battle."

— Sun Tzu, The Art of War

Who do we want to – or need to – guard against?

What are you securing your system against?

And from whom?

- You accidentally deleting important system files?
- Your colleagues not being able to look at your files on a file server?
- A company trying to find out about you and get personal data?
- A phone carrier tracking your movement?
- A grenade destroying your system?
- Video surveillance on streets?
- The NSA?

How motivated are enemies to attack you?

Who are the adversaries?

- **Hackers**
  - Good or evil (or in between)
    - **Black hat hackers**: break into systems with malicious intent
    - **White hat hackers**: "ethical hackers" – discover vulnerabilities to help safeguard organizations
    - **Gray hat hackers**: in between – search for vulnerabilities without permission; may request payment
  - Test boundaries of the system – get to know the system better than the designers
  - Only a small % are smart
  - Bug hunters – find vulnerabilities
  - Exploit writers – write code to exploit the vulnerabilities
- **Criminals**
  - Individuals or small groups
  - Don’t necessarily reap huge $ but are often creative

Who are the adversaries?

- **Malicious insiders**
  - Insidious because they are indistinguishable from legitimate, trusted insiders
  - Perimeter defenses don't work
  - Often have high levels of access
- **Industrial spies**
  - Product designs, trade secrets, project bids, finances, employee info
  - Can hire/bribe employees to reveal trade secrets or become inside attackers
  - … or resort to dumpster diving
  - **Risk-averse**: reputation of company (or country) damaged if caught

https://www.idwatchdog.com/insider-threats-and-data-breaches

Who are the adversaries?

- **Press (& politicians)**
  - Social engineering, bribing, dumpster diving, track movements, eavesdrop, break in
  - Also generally risk averse for fear of losing one's reputation & career
- **Organized crime**
  - More opportunities to make or launder money!
  - Money laundering is easier with EFT and cryptocurrency
- **Police**
  - Risk averse but have law on their side (e.g., search warrants, seizing evidence)
  - Not above breaking law: wiretaps, destruction of evidence, disabling body cameras, illegal search & seizure

Organized Crime

Example: Russian Business Network (RBN)

- **Operates on numerous ISPs worldwide**
- **Internet service provider run by criminals for criminals**
  - Host platform for illegal businesses
- **Domains registered to anonymous addresses**
  - Does not advertise
  - Trades in untraceable electronic transactions
- **Known for delivering fake anti-spyware & anti-malware software**
  - Used for PC hijacking and personal identity theft
- **One of the world's worst spammer, malware, and phishing networks**

Who are the adversaries?

- **Hacktivists, Terrorists (freedom fighters)**
  - Motivated by geopolitics, religion, or a set of ethics
  - Examples:
    - **Anonymous Sudan** – targets anti-Muslim activities but may be Russian-backed
    - **Cyber Partisans** – Belarusian hacktivists against the Belarusian government
    - **DCLeaks** – claims to be Americans concerned with freedom of speech but at least some individuals were Russian
    - **Decocidio** – an autonomous hacking group part of Earth First, a radical environmental protest group
    - **Honker Union** – group in China mostly attacking U.S. websites
    - **Garnesia_Team**, **Moroccan Black Cyber Army** – pro-Palestinian attacks
    - **Ukrainian Cyber Alliance** – Ukrainian hackers fighting Russia
  - Usually more concerned with causing harm than getting specific information
  - Often (but not always) has low budgets & low skill levels
  - Some groups have grown more sophisticated
    - *IT Army of Ukraine* vs. Russia's *KillNet* group



Hacktivist Group Leaks Disney's Slack Channels Over its Stance on AI Images

PetaPixel

Matt Growcoot • July 17, 2024

A group of hacktivists has leaked over a terabyte of data from Disney's internal communications platform over the company's stance on AI imagery.

The group called NullBulge released the data from Disney's Slack channels yesterday through a peer-to-peer network. It says it is motivated to "protect artists' rights and ensure fair compensation for their work".

That is different from a hacker's usual modus operandi who often demand ransoms. NullBulge leaked the dossier of photos, converstations, and unreleased projects quite quickly saying that making demands from Disney would be futile.

https://petapixel.com/2024/07/17/hacktivist-group-leaks-disneys-slack-channels-over-its-stance-on-ai-images/

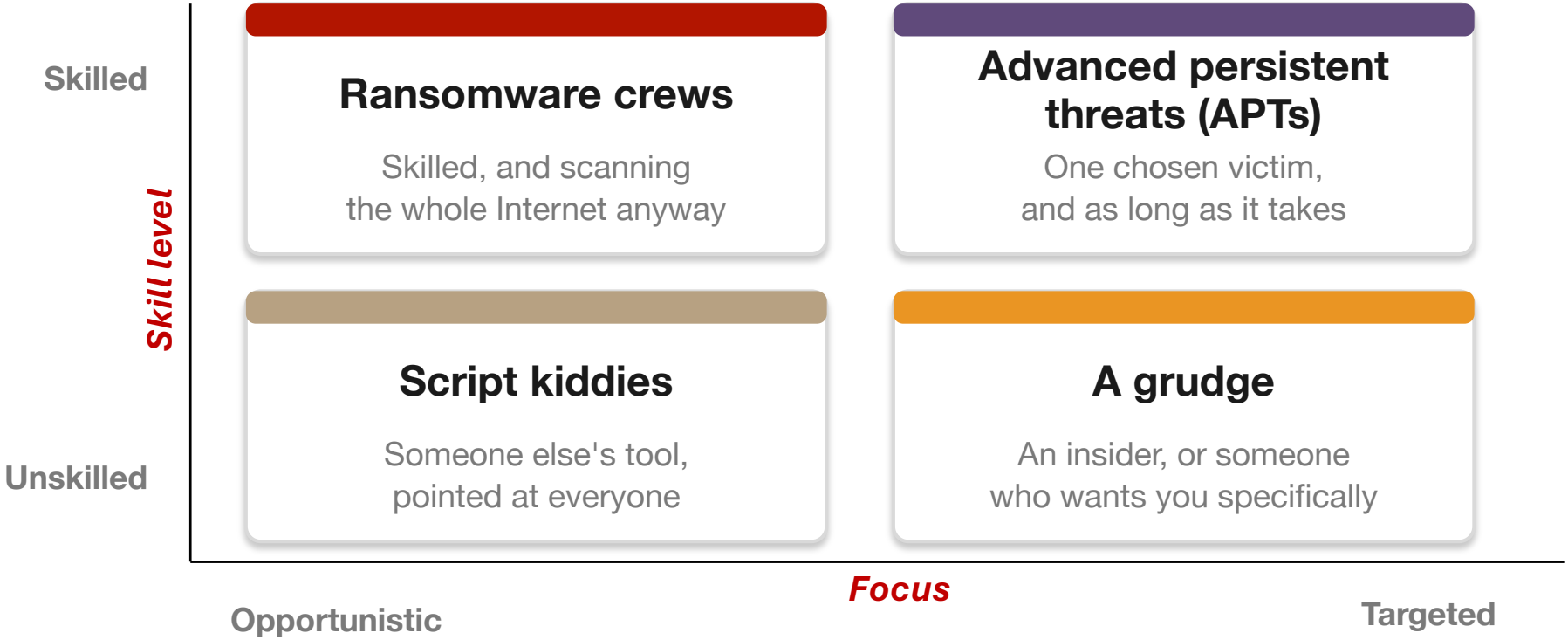
Who are the adversaries?

- **National intelligence organizations, Nation states**
  - Huge money & long-term goals
  - Somewhat risk averse
    - Bad public relations
    - Do not want leaks to reveal attack techniques
  - Often have a lot of influence
    - NSA was instrumental in the adoption of 56-bit keys for DES or the Dual_EC_DRBG (Dual Elliptic Curve Deterministic Random Bit Generator)
    - Lenovo computers, owned partially by the Chinese government's Academy of Sciences has been accused of "malicious circuits" built into the computers (not proven)
    - NSA planted backdoors into Cisco routers built for export that allow the NSA to intercept any communications through those routers.

The different characteristics of attackers

- **Goals**
- **Levels of access**
- **Risk tolerance**
- **Resources**
- **Expertise**

The Threat Matrix: Skill vs. Focus



Focus is not a skill. Skilled attackers are often opportunistic because it is cheaper.

Script Kiddies

- **Nov 2024: Script Kiddie 'Matrix' Builds Massive Botnet** [link]
  - Likely Russian Hacker Exploits IoT Vulnerabilities, Many Known for Years
  - Exploits IoT device vulnerabilities such as default credentials and outdated software.
  - Heavy reliance on external scripts and existing tools
- **July 2024: New FishXProxy Phishing Kit Making Phishing Accessible to Script Kiddies** [link]
  - A new phishing kit, FishXProxy, makes it alarmingly easy for cybercriminals to launch deceptive attacks.
- **July 2024: Botnets are being sold on the dark web for as little as $99** [link]
  - More than 20 offers for botnets for hire or sale have been discovered on dark web forums and Telegram channels this year
- **Jan 2023: ChatGPT is enabling script kiddies to write functional malware** [link]
- **Nov 2019: Wannabe Fraudsters Can Buy Hacking Tools on Dark Web** [link]
  - Prices Start as Low as a Cup of Coffee

Launching a Ransomware Attack Against a Nation Is Far Easier Than You Think

Newsweek

Naveed Jamali, Tom O'Connor, Alex J.. Rouhandeh • July 8, 2021

As ransomware attacks surge to unprecedented levels, the intricacies of mounting such a potentially destructive and deceptive operation would seem to be far beyond the reach of the average netizen.

But the power to paralyze a company or a nation with malicious intent may be more readily available than is commonly thought—although it is illegal, especially for users in the United States.

A U.S. military cyberwarfare officer who spoke to Newsweek on the condition of anonymity described a very simple process for doing a great deal of damage.

"All you need is a Tor Browser and the links to the right underground markets," the officer said. "There's forums, and you can Google them."

...

It's not unlike buying a third-party smartphone application, a pre-packaged bundle of code that enables a device to perform a large range of functions with convenience. And just as consumers can download apps from leading social media companies such as Facebook, Twitter and TikTok, prospective hackers can buy the tools used by top collectives such as REvil.

https://www.newsweek.com/launching-ransomware-attack-against-nation-far-easier-you-think-1608108

"All the News That's Fit to Print"

The New York Times

Late Edition
Today, overcast, breezy, chilly, rain, high 56. Tonight, cloudy, a bit of rain, low 52. Tomorrow, early showers, then some sunshine, warmer, high 67. Weather map is on Page 26.

VOL. CLXX . . . No. 59,074 © 2021 The New York Times Company NEW YORK, SUNDAY, MAY 30, 2021 $6.00

From Russians, Ransomware, Made to Order

This article is by Andrew E. Kramer, Michael Schwirtz and Anton Troianovski.

MOSCOW — Just weeks before the ransomware gang known as DarkSide attacked a major American pipeline, disrupting gasoline and jet fuel deliveries up and down the East Coast of the United States, the group was turning the screws on a small, family-owned publisher based in the American Midwest.

Working with a hacker who went by the name of Woris, DarkSide launched a series of attacks meant to shut down the websites of the publisher, which works mainly with clients in primary school education, if it refused to meet a $1.75 million ransom demand. It even threatened to contact the company's clients to falsely warn them that it had obtained information the gang said could be used by pedophiles to make fake identification cards that would allow them to enter schools.

Woris thought this last ploy was a particularly nice touch.

"I laughed to the depth of my soul about the leaked IDs possibly being used by pedophiles to enter the school," he said in Russian in a secret chat with DarkSide obtained by The New York Times. "I didn't think it would scare them that much."

DarkSide's attack on the pipeline owner, Georgia-based Colonial Pipeline, did not just thrust the gang onto the international stage. It also cast a spotlight on a rapidly expanding criminal industry based primarily in Russia that has morphed from a specialty demanding highly sophisticated hacking skills into a conveyor-belt-like process. Now, even

Continued on Page 14

Script Kiddies, And What Changed

- **Low-skilled attackers using tools built by others**
- **December 2025 to February 2026**
  - A small group breached nine Mexican government bodies
  - They used commercial AI coding assistants to write exploits and build tooling
  - And to organize stolen data and decide what to attack next
  - They got past the products' safeguards by calling it authorized testing

AI lowered the cost of writing code.
Humans still have to pick a good target and stay hidden for weeks once inside.

Advanced Persistent Threats

- **Advanced:** expertise and tradecraft across multiple attack vectors
- **Persistent:** objectives pursued repeatedly, over years
- **Threat:** the resources, capability, and intent to cause harm

Many are state-sponsored

  - But attribution can be difficult

Not defined by using unknown vulnerabilities

Not defined by creating custom malware

Defined by duration

Stuxnet – 2010, U.S. & Israel (?)

- **Targeted centrifuges used to purify uranium in Iran**
- **Attacked Siemens centrifuges via a SCADA interface**
  - **Systems were air-gapped**
  - **Phase 1: propagate & search**
    - Possible initial installation via thumb drive to get around the air gap
    - Propagated across Microsoft Windows Systems
    - Searched for systems running Siemens Step7 control software
  - **Phase 2: attack**
    - Altered the spin of the centrifuges while making it look like everything was fine

Showed that cyber attacks can cause real-world damage

- **Pipelines, electric grids, water plants, banking, … are at risk**

Offensive Operations By Private Companies

August 13, 2026:
a presidential memorandum

A state importing the profit motive into offensive operations

- Vetted companies may run offensive operations abroad against foreign criminal infrastructure, including spyware
- Controls: $1M escrow, dual agency approval, no U.S. targets allowed
- Critics warn of non-uniformed combatant status
- The press calls them “cyber privateers”

Are U.S. intelligence efforts secure?

Government agencies try to develop – and pay for – the best attacking & defense techniques

But they're not always good with their own systems and secrets…

The American Military Sucks at Cybersecurity

A new report from US military watchdogs outlines hundreds of cybersecurity vulnerabilities.

Matthew Gault • January 23, 2019



The Department of Defense is terrible at cybersecurity. That's the assessment of the Pentagon's Inspector General (IG), who did a deep dive into the American military's ability to keep its cyber shit on lockdown. The results aren't great. "As of September 30, 2018, there were 266 open cybersecurity-related recommendations, dating as far back as 2008," the Inspector General said in a new report.

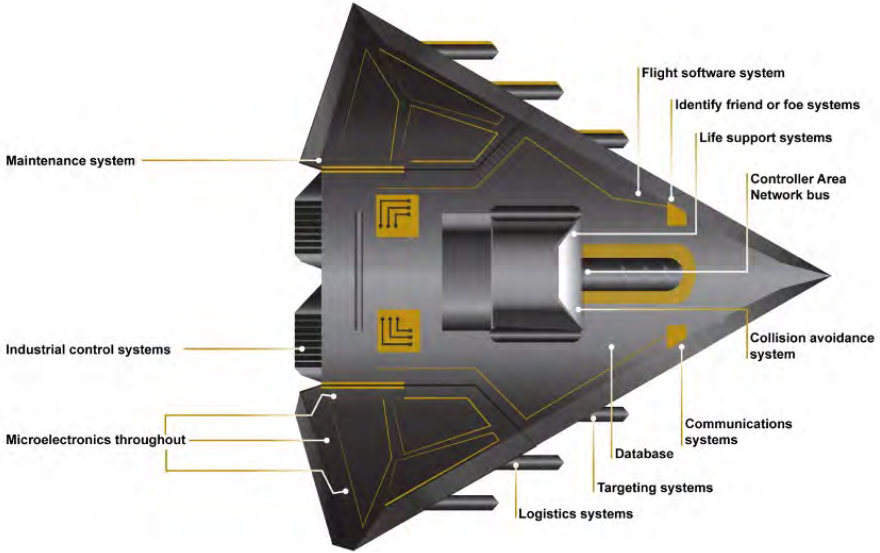
The new report is a summary of the IG's investigations into Pentagon cybersecurity over the previous year. It looked at 20 unclassified and four classified reports that detailed problems with cybersecurity and followed up to see if they'd been addressed. Previously, the IG had recommended the Pentagon take 159 different steps to improve security. It only took 19 of them.

https://motherboard.vice.com/en_us/article/7xy5ky/the-american-military-sucks-at-cybersecurity

BLEEPINGCOMPUTER

US Advanced Weaponry Is Easy to Hack, Even by Low-Skilled Attackers

By Ionut Ilascu • October 9, 2018



Major weapon systems developed by the US Department of Defense are riddled with vulnerabilities that make them an easy target for adversaries trying to control them or disrupt their functions.

As the DoD plans to spend about $1.66 trillion to advance its weapons arsenal, the US Government of Accountability Office (GAO) finds reports from various development stages of the systems showing that mission-critical vulnerabilities are a regular find in "nearly all weapon systems that were under development."

Testing teams charged with probing the resilience to cyber attacks were able to take control or disable the target using basic tools and techniques. Sometimes, just scanning the system caused parts of it to shut down.

https://www.bleepingcomputer.com/news/security/us-advanced-weaponry-is-easy-to-hack-even-by-low-skilled-attackers/

Sept 2013 – Edward Snowden's leak of NSA data

- **Former NSA contractor stole >50 TB of highly sensitive data**
- **Includes 75% of hacking tools belonging to NSA's Tailored Access Operations**
- ***"took NSA materials home so that he could become better at his job"***
- ***"Theft came to light during the investigation of a series of NSA-developed exploits that were mysteriously published online by a group calling itself Shadow Brokers."***



arstechnica.com/tech-policy/2017/02/

ars TECHNICA STORE SIGN IN

POLICY —

Former NSA contractor may have stolen 75% of TAO's elite hacking tools

Prosecutors reportedly plan to charge Harold T. Martin with espionage.

DAN GOODIN - 2/6/2017, 8:05 PM

On Monday, *The Washington Post* reported one of the most stunning breaches of security ever. A former NSA contractor, the paper said, stole more than 50 terabytes of highly sensitive data. According to one source, that includes more than 75 percent of the hacking tools belonging to the Tailored Access Operations. TAO is an elite hacking unit that develops and deploys some of the world's most sophisticated software exploits.

Attorneys representing Harold T. Martin III have previously portrayed the former NSA contractor as a patriot who took NSA materials home so that he could become better at his job. Meanwhile, investigators who have combed through his home in Glen Burnie, Maryland, remain concerned that he passed the weaponized hacking tools to enemies. The theft came to light during the investigation of a series of NSA-developed exploits that were mysteriously published online by a group calling itself Shadow Brokers.

FURTHER READING
Confirmed: hacking tool leak came from "omnipotent" NSA-tied group

Investigators have floated several theories. One holds that Martin directly provided the tools to the person or group responsible for the leak. An alternate theory is that the leakers obtained the software by hacking Martin. As reported in October, Martin was charged with felony theft of government property and unauthorized removal and retention of classified material. Monday's *Washington Post* article says that prosecutors will likely file charges of "violating the Espionage Act by 'willfully' retaining information that relates to the national defense, including classified data such as NSA hacking tools and operational plans against 'a known enemy' of the United States."

An unnamed US official told the paper that Martin allegedly hoarded more than 75 percent of the TAO's library of hacking tools. It's hard to envision a scenario under which a theft of that much classified material by a single individual would be possible.

When Shadow Brokers appeared in October, it published hundreds of TAO-developed exploits, including one that, for years, had exploited what was then a critical unknown vulnerability in a widely used firewall sold by Cisco Systems. Last month, the person or group said it was shutting down in a post that dumped 61 Windows-formatted binary files. Whether Martin was somehow involved with Shadow Brokers or was a compulsive hoarder working alone, the events underscore serious security lapses inside the NSA.

FURTHER READING
NSA-leaking Shadow Brokers lob Molotov cocktail before exiting world stage

Listing image by National Security Agency

March 2017 – Wikileaks publishes CIA Vault 7

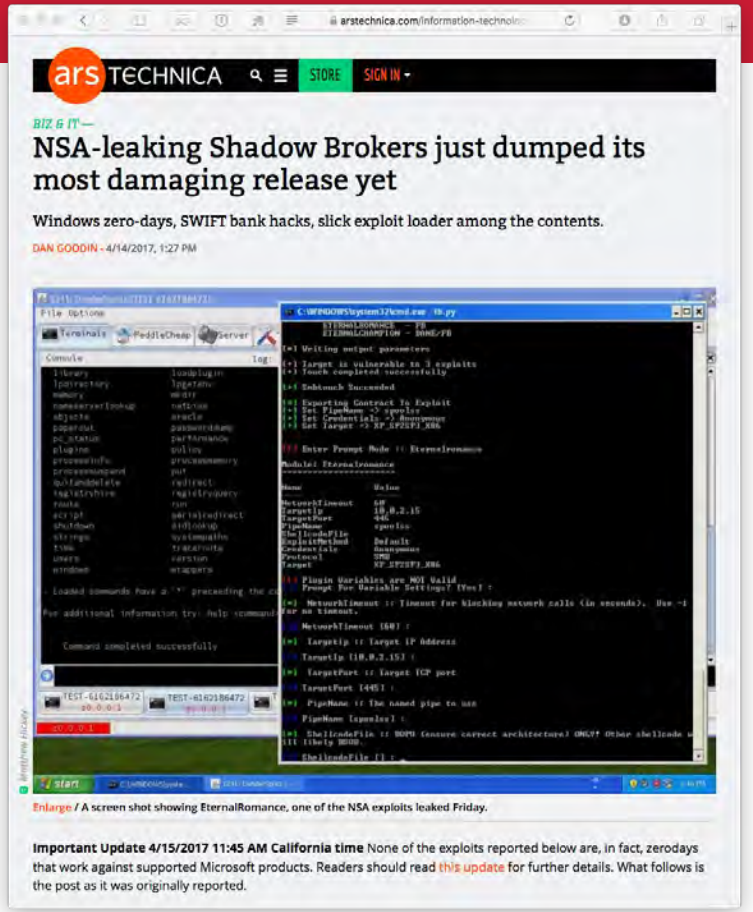
- **8,761 documents stolen from the CIA**
- **Document spying operations & hacking tools**
- **iOS and Android vulnerabilities**
- **Bugs in Windows**
- **Ability to turn some smart TVs into listening devices**

April 2017 – Theft from the NSA

Shadow Brokers

Group that leaked a gigabyte of the National Security Agency's weaponized software exploits over an eight-month period

Most vulnerabilities were patched
… but lots of systems never get updated



arstechnica.com/information-technolo...

ars TECHNICA STORE SIGN IN

BIZ & IT

NSA-leaking Shadow Brokers just dumped its most damaging release yet

Windows zero-days, SWIFT bank hacks, slick exploit loader among the contents.

DAN GOODIN - 4/14/2017, 1:27 PM

Enlarge / A screen shot showing EternalRomance, one of the NSA exploits leaked Friday.

Important Update 4/15/2017 11:45 AM California time None of the exploits reported below are, in fact, zerodays that work against supported Microsoft products. Readers should read this update for further details. What follows is the post as it was originally reported.

It’s Still a Problem

2025: Fed inspector general reports CFPB cybersecurity is lacking

A recent audit by the Federal Reserve Office of Inspector General found that the Consumer Financial Protection Bureau’s cybersecurity practices have weakened in recent months, worsened by staff and contractor shortages.

https://www.texasbankers.com/fed-inspector-general-reports-cfpb-cybersecurity-is-lacking/

The Department of Energy's Unclassified Cybersecurity Program

.. while the Department, including the National Nuclear Security Administration, has acted on some previously identified cybersecurity weaknesses, significant gaps remain. Of 63 recommendations from prior audits and evaluations, the OIG report identified that only 19 were closed, leaving 44 still open.

https://industrialcyber.co/reports/doe-oig-report-flags-systemic-shortcomings-across-nist-cybersecurity-framework-functions/

It’s Still a Problem

Office of the Inspector General: Department of the Interior

September 2025

DOI is not consistently reducing cybersecurity risks by remediating software vulnerabilities that have been rated as the most severe. Specifically, we found 9,384 vulnerabilities on DOI systems identified by the U.S. Department of Homeland Security’s Cybersecurity and Infrastructure Security Agency (CISA) as “known exploited vulnerabilities” (KEVs) that had not been remediated within the mandated timeframe. KEVs are the highest priority for remediation, as they have been identified by CISA as being actively exploited by malicious cyber actors. We also found a total of 153,665 critical and high impact vulnerabilities on DOI systems that were not remediated within required timeframes.

https://www.oversight.gov/reports/dois-software-vulnerability-identification-and-remediation-practices-svirp

Countermeasures

Court-authorized botnet operations

Seize the command servers,
redirect the domains

Provider-led takedowns

A company gets an injunction
and seizes criminal domains

Government malware removal

In 2023 the FBI spoke Snake's own protocol and told it to overwrite itself

Helpful worms

The same cleanup, spreading
by itself, with nobody's permission

Authorized — **Not authorized**

Hack-Backs

- **A hack-back is offensive action by a victim against an attacker**
- **For private entities in the United States, generally unlawful**
- **And a bad idea for reasons unrelated to the law**
- **The apparent source is often an innocent party's compromised server**

Attribution is uncertain

Evidence gets destroyed

Escalation is possible

What’s in a name?

Naming the attackers – what we see in news articles

"Chinese state-backed hackers known as Salt Typhoon allegedly targeted their latest victims: Charter Communications, Consolidated Communications, and Windstream."

"APT-36 Uses New TTPs and New Tools to Target Indian Governmental Organizations"

"Iranian Imperial Kitten hackers targeted Israeli organizations in October"

Advanced Persistent Threat (APT)

Sophisticated and prolonged cyberattack conducted by a well-funded and highly skilled group, often nation-states or state-sponsored groups

- **Advanced**
  - Use of highly targeted and customized attack methods, tools, and exploits
- **Persistent**
  - Often operate stealthily over months or years
- **Threat**
  - The attackers are capable of bypassing traditional security defenses

Examples:

China's APT41, Russia's Fancy Bear, North Korea's Lazarus Group

Naming APT Groups is Difficult and Messy

- **Challenges**
  - Attackers conceal their identities
  - Reuse tools
  - Operate through compromised infrastructure to hide their origin
  - Any technical indications can be misleading or shared across multiple groups
- **Naming**
  - Different security vendors, governments, and researchers may interpret the same evidence differently
  - Each organization uses its own system to name groups
  - This creates overlapping names for the same threat actor

Example: one Russia-linked group has multiple names: APT28, Fancy Bear, Forest Blizzard, Sednit, Sofacy, Tsar Team

Naming Schemes for APT Groups

Names usually come from organizations that identify the attacker

- There is no standard naming convention

1. APT Numbering

Coined by Mandiant

- Sequential numbers in order of discovery
  - **APT1** – attributed to the 2nd Bureau of China's People's Liberation Army – Unit 6139
  - **APT29** – attributed to Russia's Foreign Intelligence Service

2. Animal Themes

Used by CrowdStrike

- **Panda**: Chinese APTs (Deep Panda, Gothic Panda, …)
- **Bear**: Russian APTs (Cozy Bear, Fancy Bear, …)
- **Kitten**: Iranian APTs (Charming Kitten)
- **Tiger**: Indian APTs (Patchwork Tiger)

Naming Schemes for APT Groups

3. Numeric Codes

Used by FireEye, Palo Alto Networks

- E.g., **Group-3390**, **UNC2452**
- Tracked until more details are confirmed about their origin

4. Threat Actor Names

Named after campaigns or characteristics

- **Lazarus Group**: North Korean group infamous for the Sony Pictures hack
- **Equation Group**: allegedly linked to the U.S. NSA
- **Buckeye**: either the U.S. or China

5. Microsoft Naming Scheme

Two-word combination of

Weather – identifies geography

Adjective or *noun*: identifies the group

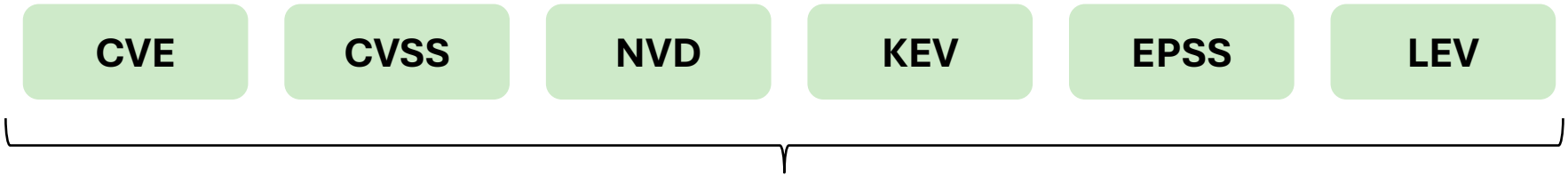
- Weather Terms
  - **Typhoon**: China
  - **Cyclone**: Iran
  - **Blizzard**: Russia
  - **Sleet**: North Korea
  - **Sandstorm**: Middle East
  - **Tempest**: Financially-motivated groups
  - **Storm**: Unknown threat group
- E.g., Salt Typhoon, Midnight Blizzard

Will This Get Easier?

- **No. Companies can't agree on identifying and naming threat actors**
- **But … in June 2025, Microsoft and CrowdStrike worked together to create a mapping of names for the same actor**
- **The hope is that this can eventually lead to some standard for naming**

MSFT	CRWD
AMETHYST RAIN	VOLCANIC TIMBER
AQUA BLIZZARD	PRIMITIVE BEAR
BRASS TYPHOON	WICKED PANDA
BROCADE TYPHOON	GOTHIC PANDA
BURGUNDY SANDSTORM	REMIX KITTEN
CADET BLIZZARD	EMBER BEAR
CANARY TYPHOON	CIRCUIT PANDA
CANVAS CYCLONE	OCEAN BUFFALO
CHARCOAL TYPHOON	AQUATIC PANDA
CHECKERED TYPHOON	DEEP PANDA
CINNAMON TEMPEST	HIGHGROUND
CIRCLE TYPHOON	EMISSARY PANDA

Tracking vulnerabilities & risks



What are all these letters??

Tracking Vulnerabilities

When new software flaws are discovered, we need a way to track, rate, and respond to them consistently

The security community uses a set of shared systems to do this

- **CVE**: Provides unique identifiers for reported vulnerabilities
- **CVSS**: scores their severity
- **NVD**: U.S. government database that tracks this information
- **KEV**: lists known vulnerabilities that demand urgent attention
- **EPSS**: predicts the likelihood of exploitation
- **LEV**: helps companies prioritize which bugs to address

- **You don't need to memorize these, but you should know they exist**
  - **CVEE** and **CVSS** show up in a lot of cybersecurity articles

Tracking Vulnerabilities With CVE

CVE (Common Vulnerabilities and Exposures)

A standardized system for identifying, defining, and cataloging publicly disclosed cybersecurity vulnerabilities

- Managed by **MITRE Corporation** at www.cve.org
- Sponsored by the U.S. Department of Homeland Security (DHS) and the Cybersecurity and Infrastructure Security Agency (CISA)
  - Currently contains over 368 records and growing
  - The latest records are posted on https://x.com/CVEnew

- **Structure: CVE-[Year]-[Number]**
- **Example: CVE-2024-11477**

  7-Zip Zstandard Decompression Integer Underflow Remote Code Execution Vulnerability

CVSS: Vulnerability Scoring

- ***How severe is the vulnerability?***
- ***Should I take steps immediately or is the risk of an exploit low?***

Common Vulnerability Scoring System (CVSS)

- A framework for rating the severity of vulnerabilities on a scale of 0 to 10

- **Severity Levels**
  - 0.0 – 3.9: Low
  - 4.0 – 6.9: Medium
  - 7.0 – 8.9: High
  - 9.0 – 10.0: Critical

Example: CVE-2021-44228 (Log4Shell)

- **Base Score:** 10.0 (Critical).
- **Attack Vector:** Remote.
- **Impact:** Full system compromise.

MITRE does not store CVSS data – it only stores the ID, brief description, affected product, and references

A Recent Example: CVSS 9.8

The Hacker News

Critical Cisco Nexus 9000 Flaw Lets Unauthenticated Remote Attackers Run Code as Root

Swati Khandelwal • September 3, 2026

Cisco has released patches to address a critical security flaw affecting 10 Silicon One-based Nexus 9000 switches that could allow an unauthenticated, remote attacker to execute code as root, alongside an IOS XR hardening release bundling 7 umbrella CVEs, 2 of which are rated 9.8, with no workaround for any IOS XR version.

The Nexus vulnerability, tracked as CVE-2026-20212 (CVSS score: 9.8), is a case of binding to an unrestricted IP address that leaves TCP ports 43210 and 43211 reachable in the default Layer 3 virtual routing and forwarding (VRF) instance.

An attacker who can reach a switch's address on either port can connect directly to the service. Crafted input sent to that service is then executed as code with root privileges. An exploitation attempt can also crash the S1HAL process and reload the device.

https://thehackernews.com/2026/09/critical-cisco-nexus-9000-flaw-lets.html

NVD: A database that stores CVEs

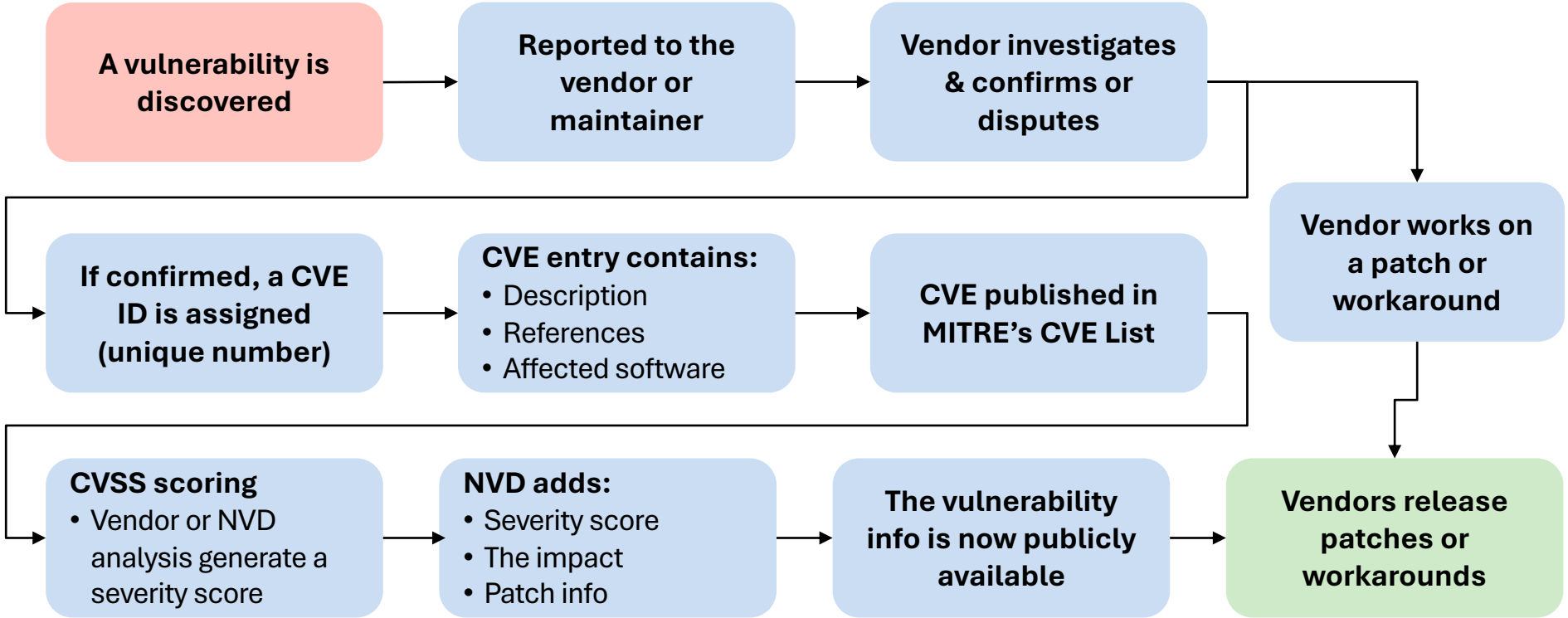
MITRE does not store CVSS data – it only stores:

- ID (CVE identifier)
- A brief description
- Affected product or vendor
- References

National Vulnerability Database (NVD) : https://nvd.nist.gov

- Maintained by the National Institute of Standards & Technology (NIST)
- Enriches the CVE reports with:
  - CVSS scores (impact/severity assignment)
  - Standardized product names
  - Additional metadata and references

Flow: From Bug Discovery to CVE and CVSS



Known Exploited Vulnerabilities (**KEV**) Dataset

- **Subset of CVEs that have been confirmed as actively exploited**
  - CVEs cover all documented vulnerabilities
  - KEVs cover only those actively exploited – considered higher priority
- **KEVs are curated by CISA (Cybersecurity and Infrastructure Security Agency)**
  - The purpose is to identify vulnerabilities that present immediate risks
  - It helps organizations focus their efforts on patching vulnerabilities that pose the greatest risk

https://www.cisa.gov/known-exploited-vulnerabilities-catalog

Exploit Prediction Scoring System (EPSS)

Data-driven model developed by FIRST.org to estimate the probability that a vulnerability will be exploited in the wild within the next 30 days

Daily file downloads from `https://www.first.org/epss/data`

- **CVE:** Identification of the vulnerability
  MITRE's CVE list
- **EPSS:** The probability of exploitation in the wild during the next 30 days
  A CVE with EPSS of 0.90 has a 90% chance of being exploited in the next 30 days
- **Percentile:**
  Ranking of this vulnerability vs. others on the list
  A CVE with a percentile of 0.82 means that 82% of other CVEs have a lower EPSS score

cve	epss	percentile
CVE-2026-9981	0.00191	0.08765
CVE-2026-9982	0.00184	0.08104
CVE-2026-9983	0.00255	0.16930
CVE-2026-9984	0.00234	0.14183
CVE-2026-9985	0.00182	0.07874
CVE-2026-9986	0.00145	0.04037
CVE-2026-9987	0.00099	0.00896

https://www.first.org/epss/

https://orca.security/resources/blog/epss-scoring-system-explained/

Exploit Prediction Scoring System (EPSS)

- **Scores are computed via a machine learning algorithm**
- **Proprietary process – trained on data of**
  - Exploitations observed during the past day
    - From reports from companies and project partners
  - Vendor, age, CVSS, Common Weakness Enumeration (CWE)
- **The model learns the relationship between vulnerabilities and the exploitation attempts observed**

https://www.first.org/epss/

https://orca.security/resources/blog/epss-scoring-system-explained/

Likely Exploited Vulnerabilities (LEV)

A new metric proposed by the NIST in May 2025

Why not use EPSS or KEV?

- **EPSS** : global model that predicts the likelihood that someone, somewhere will exploit a CVE
- **KEV** catalogs known exploited vulnerabilities but lacks metrics to prioritize exploits

LEV

- Organization-specific model: assess how much the vulnerability matters in your own environment
- Is the software actually deployed internally?
- Is the software public-facing or isolated?
- What is the value of the asset (customer database vs. lab test machine)?
- Ease of exploitation in the local configuration

Note: LEV was proposed by NIST in 2025 and is not yet widely adopted – it is not a standard.

https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.41.pdf

https://www.infosecurity-magazine.com/news/nist-metric-lev-likelihood/

Lots of abbreviations!!

- **CVE: an identification of the vulnerability**
- **CVSS: how bad it could be**
- **NVD: the database where this information is stored**
- **EPSS: how likely it is to happen**
- **KEV: proof that it is happening now**
- **LEV: how much it matters to you**

CVSS Report Data

Example: A March 2026 Oracle Identity Manager product of Oracle Fusion

CVE-2026-21992 (https://nvd.nist.gov/vuln/detail/CVE-2026-21992)

CVE-2026-21992 Detail

Description

Vulnerability in the Oracle Identity Manager product of Oracle Fusion Middleware (component: REST WebServices) and Oracle Web Services Manager product of Oracle Fusion Middleware (component: Web Services Security). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.1.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Identity Manager and Oracle Web Services Manager. Successful attacks of this vulnerability can result in takeover of Oracle Identity Manager and Oracle Web Services Manager. Note: Oracle Web Services Manager is installed with an Oracle Fusion Middleware Infrastructure. CVSS 3.1 Base Score 9.8 (Confidentiality, Integrity and Availability impacts). CVSS Vector: (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H).

QUICK INFO

CVE Dictionary Entry:
CVE-2026-21992
NVD Published Date:
03/19/2026
NVD Last Modified:
03/23/2026
Source:
Oracle

Metrics

CVSS Version 4.0 | CVSS Version 3.x | CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:

CNA: Oracle	Base Score:	Vector:
	9.8 CRITICAL	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CVSS Report Data

Example: A March 2026 Oracle Identity Manager product of Oracle Fusion

CVE-2026

CNA: Oracle **Base Score:** 9.8 CRITICAL **Vector:** CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CVE

Description

Vulnerability in the Oracle Identity Manager product of Oracle Fusion Middleware (component: REST WebServices) and Oracle Web Services Manager product of Oracle Fusion Middleware (component: Web Services Security). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.1.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Identity Manager and Oracle Web Services Manager. Successful attacks of this vulnerability can result in takeover of Oracle Identity Manager and Oracle Web Services Manager. Note: Oracle Web Services Manager is installed with an Oracle Fusion Middleware Infrastructure. CVSS 3.1 Base Score 9.8 (Confidentiality, Integrity and Availability impacts). CVSS Vector: (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H).

QUICK INFO

CVE Dictionary Entry:
CVE-2026-21992
NVD Published Date:
03/19/2026
NVD Last Modified:
03/23/2026
Source:
Oracle

Metrics

CVSS Version 4.0 | CVSS Version 3.x | CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:

CNA: Oracle **Base Score:** 9.8 CRITICAL **Vector:** CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CVSS Report Data - Fields

https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator CVE-2026-21992

CNA: Oracle

Base Score:

9.8 CRITICAL

Vector:

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/
S:U/C:H/I:H/A:H

CAN	CVE Numbering Authority : **Oracle**
Base Score	Vulnerability Score:**9.8 - Critical**
CVSS:3.1	CVSS version: **3.1**
AV:N	Attack Vector: **network**
AC:L	Attack Complexity: **low**
PR:N	Privilege Required: **none**
UI:N	User Interaction: **none**
S:U	Scope: **unchanged**
C:H	Confidentiality Impact: **high**
I:H	Integrity Impact: **high**
A:H	Availability Impact: **high**

You don't have to remember the naming of adversaries or the vulnerability identification sequence, but the names come up frequently in articles

CVE and CVSS are important to know

The End